

VirtuEx 시스템 감사 보고서 (16차)

VirtuEx System Audit Report (16th)

- 감사일: 2026-03-15
- 감사 범위: 대시보드 HTML 구조, 카피트레이딩 데이터 흐름, 회원관리 필터, 커뮤니티 보안, 주문 폼 안정성
- 감사 방법: 전체 소스 코드 정적 분석 + 컴포넌트 계층 검증 + API 데이터 흐름 추적
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 발견 사항만 기록하며, 수정은 포함하지 않음

이전 감사 대비 수정 현황 (15차 → 16차)

이전 이슈	상태	비고
[UI-H-01] 대시보드 AI 분석 버튼 위치 불일치	수정됨	AI 버튼을 필터 섹션 우측 끝으로 이동, AssetList props로 분리
[UI-M-01] 토스트 알림 위치 불일치	수정됨	전체 토스트 우측 하단으로 통일
[LB-C-01] 리더보드 조회 기본 한도 20명	수정됨	limit=100 명시적 전달
button-in-button HTML 오류	수정됨	모바일 필터 토글을 div로 변경하여 중첩 버튼 제거
카피트레이딩 페이지네이션 누락	수정됨	백엔드 totalPages 계산 추가

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 보안/XSS	1	1	0	0	2
B. 커뮤니티 게시판	1	0	2	1	4
C. 주문/거래	0	2	1	0	3
D. 알림/상태 동기화	0	1	1	1	3
E. 회원관리/인증	0	0	2	1	3
F. 카피트레이딩	0	1	1	1	3
합계	2	5	7	4	18

A. 보안/XSS — 2건

[SEC-C-01] 커뮤니티 게시글 XSS — href 프로토콜 미검증 (Critical)

현상: 커뮤니티 게시물 상세 페이지에서 DOMPurify로 HTML을 정제하지만, `href` 속성의 프로토콜을 별도 검증하지 않아 `javascript:` URL을 통한 XSS 공격 가능성 존재 **위치:** `frontend/src/app/(main)/community/[id]/page.tsx:379-382` **권장:** DOMPurify 설정에 `ALLOW_UNKNOWN_PROTOCOLS: false` 추가 및 `href` 프로토콜 화이트리스트(`http`, `https`, `mailto`) 적용 **심각도:** Critical

[SEC-H-01] 검색 입력 길이 제한 없음 — 과도한 리렌더 유발 (High)

현상: SearchBar 컴포넌트의 검색 입력에 `maxLength` 속성이 없어 매우 긴 문자열 붙여넣기 시 과도한 리플로우 및 필터링 연산 발생 **위치:** `frontend/src/components/market/SearchBar.tsx:38-44` **권장:** `maxLength={100}` 제한 및 `debounce(300ms)` 적용 **심각도:** High

B. 커뮤니티 게시판 — 4건

[CM-C-01] 게시물 작성 — 첨부파일 업로드 실패 시 에러 미처리 (Critical)

현상: `handleSubmit` 에서 파일 업로드를 순차적으로 `mutateAsync` 호출하지만, 중간 파일 업로드 실패 시 `catch` 없이 진행되어 사용자에게 어떤 파일이 실패했는지 피드백 없음. 게시글은 생성되나 첨부파일 일부 누락 가능 **위치:** `frontend/src/app/(main)/community/new/page.tsx:90-111` **권장:** 개별 파일 업로드에 `try-catch` 적용, 실패 파일 목록을 사용자에게 알림 **심각도:** Critical

[CM-M-01] 게시물 목록 페이지네이션 — 서버 사이드 미지원 (Medium)

현상: 커뮤니티 게시물 목록을 전체 조회 후 클라이언트에서 페이지네이션. 게시물 수 증가 시 초기 로딩 시간 증가 **위치:** `frontend/src/app/(main)/community/page.tsx` **권장:** 서버 사이드 페이지네이션 도입하여 필요한 페이지만 조회 **심각도:** Medium

[CM-M-02] TipTap 에디터 이미지 삽입 크기 제한 없음 (Medium)

현상: TipTap 에디터로 이미지를 삽입할 때 파일 크기 검증이 프론트엔드에서만 수행되며, 해상도/치수 제한 없음. 대용량 이미지로 페이지 렌더링 성능 저하 가능 **위치:** `frontend/src/app/(main)/community/new/page.tsx` **권장:** 이미지 최대 크기 (5MB) 및 해상도(4096×4096) 제한 추가 **심각도:** Medium

[CM-L-01] 게시물 수정 시 첨부파일 상태 초기화 (Low)

현상: 게시물 수정 기능 구현 시 기존 첨부파일 목록이 초기 상태로 로드되는지 확인 필요. 현재 수정 페이지 미구현으로 향후 구현 시 주의 필요 **권장:** 수정 페이지 구현 시 기존 첨부파일 유지/삭제 UI 반영 **심각도:** Low

C. 주문/거래 — 3건

[ORD-H-01] OrderForm 통화 전환 — 경쟁 조건 발생 가능 (High)

현상: 통화 모드 전환 시 `prevRate` 와 `prevCurrencyMode` 상태가 현재 환율과 동기화되지 않는 시점이 존재. 빠른 연속 전환 시 잘못된 환율로 가격이 계산될 수 있음 **위치:** `frontend/src/components/trading/OrderForm.tsx:113-126` **권장:** `useEffect` 내 환율 전환 로직을 단일 `atomic` 상태 업데이트로 통합 **심각도:** High

[ORD-H-02] 주문 확인 후 에러 시 UI 무응답 (High)

현상: `handleConfirmSubmit` 함수에서 API 5xx 에러 또는 네트워크 오프라인 시 글로벌 에러 핸들러에 의존하지만, 핸들러가 동작하지 않으면 사용자는 버튼이 비활성화된 상태에서 아무 피드백 없이 대기 **위치:** `frontend/src/components/trading/OrderForm.tsx:208-229` **권장:** `catch` 블록에 명시적 에러 토스트 추가 및 버튼 상태 복원 **심각도:** High

[ORD-M-01] 주문 내역 날짜 필터 — 커스텀 범위 미지원 (Medium)

현상: 주문 내역에서 기간 필터가 1일/1주/1개월 등 고정 옵션만 제공. 사용자가 특정 날짜 범위를 직접 선택할 수 없음 **위치:** `frontend/src/app/(main)/orders/page.tsx` **권장:** DatePicker 기반 커스텀 날짜 범위 선택 기능 추가 **심각도:** Medium

D. 알림/상태 동기화 — 3건

[NTF-H-01] 알림 읽음 처리 후 배지 카운트 미갱신 (High)

현상: `useMarkAsRead`, `useMarkAllAsRead` 뮤테이션이 알림 목록 캐시만 무효화하고 미읽음 카운트 캐시는 갱신하지 않아 배지에 잘못된 숫자가 잔존 **위치:** `frontend/src/hooks/useNotifications.ts:87-99, 108-120` **권장:** 뮤테이션 성공 콜백에 `['notifications', 'unread-count']` 쿼리 무효화 추가 **심각도:** High

[NTF-M-01] 실시간 알림과 폴링 알림 중복 표시 가능 (Medium)

현상: WebSocket으로 수신된 실시간 알림과 React Query 폴링으로 가져온 알림이 동일 알림일 경우 중복 표시될 수 있음 **위치:** `frontend/src/hooks/useNotifications.ts` **권장:** 알림 ID 기반 중복 제거 로직 추가 **심각도:** Medium

[NTF-L-01] 알림 빈 상태 안내 텍스트 미구분 (Low)

현상: 알림이 없을 때 "결과 없음" 등 범용 텍스트를 표시. "아직 받은 알림이 없습니다" 등 맥락에 맞는 안내가 더 적합 **위치:** `frontend/src/app/(main)/mypage/page.tsx` **권장:** 알림 전용 빈 상태 메시지 추가 **심각도:** Low

E. 회원관리/인증 — 3건

[ADM-M-01] 회원 역할 필터 — API 백엔드 미지원 (Medium)

현상: 신규 추가된 역할 필터(SYSTEM/ADMIN/USER)가 프론트엔드에서 파라미터로 전달되지만, 백엔드 API가 `role` 파라미터를 처리하는지 확인 필요. 미지원 시 필터가 동작하지 않음 **위치:** `frontend/src/app/(main)/admin/users/page.tsx`, `backend/services/user-auth/` **권장:** 백엔드 회원 조회 API에 `role` 필터 파라미터 지원 확인 및 추가 **심각도:** Medium

[ADM-M-02] 회원 목록 CSV 내보내기 기능 부재 (Medium)

현상: 관리자가 회원 목록을 외부에서 분석하기 위한 내보내기 기능이 없음. 대량 회원 관리 시 불편 **위치:** `frontend/src/app/(main)/admin/users/page.tsx` **권장:** CSV/Excel 내보내기 버튼 추가 **심각도:** Medium

[ADM-L-01] 관리자 페이지 접근 제어 — 클라이언트 전용 (Low)

현상: 관리자 페이지 접근 제어가 프론트엔드 라우팅과 미들웨어에서만 수행됨. API 게이트웨이 레벨에서의 역할 기반 접근 제어가 추가로 필요 **위치:** `frontend/src/middleware.ts`, `backend/services/api-gateway/` **권장:** API 게이트웨이에 역할 기반 라우트 가드 추가 **심각도:** Low

F. 카피트레이딩 — 3건

[CT-H-01] CopyTradeModal 중지 뮤테이션 중복 방지 — 잘못된 pending 체크 (High)

현상: 카피 트레이딩 중지 버튼 클릭 시 `updateMutation.isPending` 을 체크하지만, 실제로는 `stopMutation.isPending` 을 체크해야 함. 중지 뮤테이션 실행 중 재클릭 시 중복 요청 발생 가능 **위치:** `frontend/src/components/trading/CopyTradeModal.tsx:177-178` **권장:** `stopMutation.isPending` 조건으로 변경하여 중복 요청 방지 **심각도:** High

[CT-M-01] 카피 트레이딩 내역 — traderName 폴백 표시 불일치 (Medium)

현상: CopyTradeHistory 에서 traderName 이 없을 때 traderId?.slice(0, 8) 로 축약 표시. 사용자에게 UUID 일부가 노출되어 직관적이지 않음 **위치:** frontend/src/components/trading/CopyTradeHistory.tsx:143 **권장:** traderId 대신 "알 수 없는 트레이더" 등 사용자 친화적 폴백 또는 별도 닉네임 조회 **심각도:** Medium

[CT-L-01] 카피 트레이딩 설정 — 최소/최대 금액 입력 검증 미비 (Low)

현상: 카피 트레이딩 설정 시 최소 거래 금액이 최대 금액보다 큰 경우 프론트엔드에서 즉시 검증하지 않고 서버 검증에 의존 **위치:** frontend/src/components/trading/CopyTradeModal.tsx **권장:** 입력 시점에 $\min \leq \max$ 실시간 유효성 검사 추가 **심각도:** Low

종합 의견

16차 감사에서는 총 18건의 이슈가 발견되었습니다. 15차 감사에서 발견된 주요 이슈(대시보드 AI 버튼 배치, 리더보드 투자자 누락, 토스트 위치 불일치) 및 button-in-button HTML 오류, 카피트레이딩 페이지네이션 문제가 정상적으로 수정된 것을 확인하였습니다.

Critical 2건(커뮤니티 XSS 취약점, 첨부파일 업로드 에러 처리)은 보안 및 데이터 무결성에 직접적 영향을 미치므로 즉시 수정이 필요합니다. High 5건 중 주문 폼 경쟁 조건과 알림 배지 카운트 동기화는 사용자 경험에 직접적 영향을 미칩니다.

신규 추가된 역할 필터 기능의 백엔드 연동 상태 확인이 필요하며, 카피 트레이딩 중지 뮤테이션의 중복 요청 방지 로직 수정을 권장합니다.

본 보고서는 자동 생성된 감사 결과이며, 수정 사항은 포함되지 않습니다.